

Kepada : Direksi Teknologi Informasi / Tim Keamanan Informasi Terkait

Dari : Habib Muzakki (Tim Penguji Penetrasi Pemula & Bug Hunter)

Tanggal : Sabtu, 18 Juli 2026

Perihal : Laporan Resmi Hasil Pengujian Celah Keamanan Aplikasi (ZAP Scan Report - Latihan_Laporan_1)

LAPORAN EKSKLUSIF PEMINDAIAN KEAMANAN WEB

1. Ringkasan Eksekutif

Pada tanggal 18 Juli 2026, telah dilakukan pengujian dan pemindaian keamanan otomatis (*automated vulnerability assessment*) terhadap aset digital utama yang mencakup domain internal maupun integrasi pihak ketiga eksternal. Pengujian ini menggunakan perangkat lunak standar industri **OWASP ZAP versi 2.17.0 (ZAP by Checkmarx)** dengan target utama simulasi pada platform **OWASP Juice Shop**.

Tujuan dari pengujian ini adalah untuk mengidentifikasi kelemahan konfigurasi pada sistem (*systemic vulnerabilities*) sebelum risiko tersebut dapat dieksploitasi oleh pihak yang tidak bertanggung jawab. Hasil pemindaian menunjukkan bahwa sistem utama berada pada kondisi yang cukup stabil tanpa adanya temuan risiko tingkat tinggi (High Risk), namun memerlukan perbaikan segera pada sektor konfigurasi arsitektur keamanan tingkat menengah (Medium Risk).

2. Ruang Lingkup Pemindaian (Scope of Target)

Pemindaian dan analisis lalu lintas data dilakukan secara menyeluruh pada aset-aset berikut:

- https://juice-shop.github.io (Target Utama Aplikasi)
- https://www.google.com & https://accounts.google.com (Modul Otentikasi Terintegrasi)
- https://cdn.jsdelivr.net & https://cdnjs.cloudflare.com (Jaringan Pengiriman Konten / CDN Resmi)

3. Ringkasan Temuan Keamanan (Summary of Alerts)

Berikut adalah tabel ringkasan total celah keamanan yang terdeteksi berdasarkan tingkat keparahan risiko:

Tingkat Risiko	Jumlah Temuan	Kategori Dampak	Status Validasi
Tinggi (High)	0	-	0 False Positive
Sedang (Medium)	4	Sistemik (Menyeluruh)	Valid Terverifikasi
Lemah (Low)	3	Sistemik (Menyeluruh)	Valid Terverifikasi
Informasi (Info)	3	Struktural / Log	Catatan Sistem

4. Detail Celah Keamanan Tingkat Sedang (Medium Risk)

Celah pada tingkat ini wajib segera diperbaiki karena menyangkut standar baku pertahanan aplikasi dari serangan siber modern.

1. Content Security Policy (CSP) Header Not Set

Risiko: Sedang | **Dampak:** Sistemik | **Metode:** GET | **CWE ID:** 693

Deskripsi: Aplikasi web tidak memiliki header *Content Security Policy* (CSP). CSP sangat penting untuk mendeteksi dan memitigasi serangan seperti Cross-Site Scripting (XSS) dan injeksi data yang dapat berujung pada pencurian data kredensial atau penyebaran malware.

URL Terdampak: <https://juice-shop.github.io/>, </robots.txt>, </sitemap.xml>

Rekomendasi Solusi: Konfigurasi server web (Nginx/Apache) atau aplikasi Anda untuk mengirimkan header HTTP Content-Security-Policy dengan mendefinisikan sumber aset (JS, CSS, Gambar) yang sah secara ketat.

2. Kesalahan Konfigurasi Lintas Domain (Permissive CORS Policy)

Risiko: Sedang | **Dampak:** Sistemik | **Bukti (Evidence):** `access-control-allow-origin: *` | **CWE ID:** 264

Deskripsi: Ditemukan penggunaan tanda bintang (*) pada header CORS yang mengizinkan domain pihak ketiga mana pun untuk membaca respons dari API publik. Meskipun API ini tidak membutuhkan otentikasi, konfigurasi ini dapat disalahgunakan penyerang untuk memetakan data internal menggunakan taktik tertentu.

URL Terdampak: <https://juice-shop.github.io/>, [https://cdn.jsdelivr.net/...](https://cdn.jsdelivr.net/), [https://cdnjs.cloudflare.com/...](https://cdnjs.cloudflare.com/)

Rekomendasi Solusi: Batasi header Access-Control-Allow-Origin hanya untuk domain resmi perusahaan yang terpercaya, atau hapus jika pertukaran data lintas domain tidak diperlukan.

3. Missing Anti-clickjacking Header (X-Frame-Options)

Risiko: Sedang | **Dampak:** Sistemik | **CWE ID:** 1021

Deskripsi: Halaman web tidak memuat proteksi terhadap serangan *Clickjacking*. Absennya header ini memungkinkan penyerang membungkus situs perusahaan ke dalam bingkai transparan (iframe) di situs palsu untuk menipu pengguna agar mengklik tautan berbahaya.

URL Terdampak: https://juice-shop.github.io/tab_challenges.html, /tab_overview.html, /tab_shenanigans.html

Rekomendasi Solusi: Terapkan header HTTP X-Frame-Options: SAMEORIGIN atau gunakan direktif CSP `frame-ancestors 'self'` pada semua halaman respons web.

4. Sub Resource Integrity (SRI) Attribute Missing

Risiko: **Sedang** | Dampak: Sistemik | CWE ID: 345

Deskripsi: File eksternal (seperti stylesheet/font dari Google Fonts dan FontAwesome) dimuat tanpa menggunakan atribut integritas (hash kriptografi). Jika server pihak ketiga tersebut diretas, penyerang dapat memodifikasi file script/style untuk menyusupkan kode berbahaya ke aplikasi Anda.

Rekomendasi Solusi: Tambahkan atribut integrity yang berisi hash SHA-256/384/512 yang valid pada setiap tag `<script>` atau `<link>` yang memuat pustaka eksternal.

5. Temuan Keamanan Tingkat Lemah (Low Risk) & Informasi

Meskipun tingkat risikonya rendah, perbaikan pada sektor ini akan menyempurnakan pertahanan berlapis (*Defense-in-Depth*) perusahaan:

- **Cross-Domain JavaScript Source File Inclusion (Low):** Memuat file JavaScript eksternal dari domain luar. Pastikan sumber seperti `jsdelivr.net` selalu divalidasi dan menggunakan versi spesifik yang aman.
- **Strict-Transport-Security Header Not Set (Low):** Server tidak menegakkan koneksi HTTPS secara paksa (HSTS). Mitigasi dengan menambahkan header `Strict-Transport-Security` agar peramban selalu terhubung via jalur enkripsi.
- **X-Content-Type-Options Header Missing (Low):** Absennya opsi `nosniff` dapat memicu peramban lama melakukan MIME-sniffing yang rentan eksploitasi silang.
- **Keterbukaan Informasi - Komentar Mencurigakan (Info):** Ditemukan 67 komentar kode (seperti tag `TODO`, `BUG`, dan petunjuk fungsi internal) di berkas JavaScript. Direkomendasikan melakukan proses *minification* sebelum menayangkan kode ke server produksi guna menghapus seluruh komentar teknis.

6. Kesimpulan dan Rencana Tindak Lanjut

Secara menyeluruh, infrastruktur aplikasi web menunjukkan ketahanan yang baik terhadap serangan kritis yang bersifat merusak langsung. Namun, celah keamanan sistemik yang ditemukan di level **Sedang (Medium)** berpotensi membuka pintu gerbang bagi serangan rantai pasokan (*supply chain attack*) dan manipulasi antarmuka pengguna jika diabaikan dalam jangka panjang.

Direkomendasikan bagi tim pengembang (*development team*) bersama dengan tim operasional sistem untuk menerapkan perubahan konfigurasi header keamanan di atas pada siklus pemeliharaan berkala berikutnya.

Dibuat oleh,

Mengetahui / Diterima oleh,

Habib Muzakki

Analisis Keamanan Siber Pemula / Bug Hunter
Teknik Informatika D4 Vokasi

Tim Manajemen Keamanan Informasi / IT Enterprise